

Module 06: Authentication & Authorization

Duration: 5-7 days | **Level:** Intermediate

Session Authentication (TaskForge)

TaskForge implements session-based auth in AuthController:

```
// Login
if (Auth::attempt($credentials, $request->boolean('remember'))) {
    $request->session()->regenerate();
    return redirect()->intended(route('dashboard'));
}

// Logout
Auth::logout();
$request->session()->invalidate();
$request->session()->regenerateToken();
```

Route Protection

```
Route::middleware('guest')->group(function () {
    Route::get('/login', ...);
});

Route::middleware('auth')->group(function () {
    Route::get('/dashboard', ...);
});
```

Blade Auth Directives

```
@auth
<p>Welcome, {{ auth()->user()->name }}</p>
@endauth

@guest
<a href="{{ route('login') }}">Login</a>
@endguest
```

Laravel Breeze / Jetstream (Alternative)

For production apps, install scaffolding:

```
composer require laravel/breeze --dev
php artisan breeze:install blade
npm install && npm run build
php artisan migrate
```

Breeze provides login, register, password reset, and email verification.

Authorization with Policies

Policy - app/Policies/TaskPolicy.php:

```
public function update(User $user, Task $task): bool
{
    return $user->id === $task->user_id
    || $task->project->user_id === $user->id
    || $user->isAdmin();
}
```

Usage in controller:

```
$this->authorize('update', $task);  
// or  
abort_unless($user->can('update', $task), 403);
```

Register in AppServiceProvider:

```
Gate::policy(Task::class, TaskPolicy::class);
```

Roles (TaskForge)

```
enum UserRole: string {  
    case Admin = 'admin';  
    case Member = 'member';  
}  
  
// User model  
public function isAdmin(): bool {  
    return $this->role === UserRole::Admin;  
}
```

For complex roles, consider [spatie/laravel-permission](#).

API Authentication with Sanctum

```
// Create token  
$token = $user->createToken('api-token')->plainTextToken;  
  
// Protect routes  
Route::middleware('auth:sanctum')->group(function () { ... });  
  
// Test with Sanctum  
Sanctum::actingAs($user);
```

Exercises

1. Add middleware EnsureUserIsAdmin for admin-only routes.
 2. Prevent members from deleting projects they don't own.
 3. Create an API token via Tinker and call GET /api/tasks.
-

Next Module

-> [Module 07: REST API Development](#)